

# CyberDefense Pro 2.0

## 2.4.1 Managing Attack Surfaces

As previously described, threat models are valuable tools that allow a system to be deconstructed into its functional parts to understand better how a threat actor might exploit it. Furthermore, threat models seek to identify which threat actors will likely attempt to exploit the system. The goal of the threat model is to help determine how to improve a system's security posture, and part of this exercise often includes attack surface management and hardening.

This lesson covers the following topics:

- Attack surface
- Managing attack surfaces
- Evaluating the attack surface
- Penetration testing and adversary emulation
- Reducing the attack surface

### Attack Surface

An attack surface describes all potential pathways a threat actor could use to gain unauthorized access or control. Each piece of software, service, and every enabled protocol on an endpoint offers a unique opportunity for attack. Removing or disabling as many of these as possible can significantly reduce the number of (potentially) exploitable pathways into a system. Additionally, default configurations typically favor functionality and compatibility over security, so it is essential to understand how to customize a system to allow for the most secure type of operation, not necessarily the most convenient. Several hardening guides are available that outline secure configurations in precise detail. Two popular sources of best practice configuration include the Center for Internet Security (CIS) Benchmarks™ and the Department of Defense's Security Technical Implementation Guides (STIGs.) As of this writing, the CIS Benchmark for Windows 10 had over 1,000 pages of recommended configuration changes.

More information about DoD STIGs is available at <https://public.cyber.mil/stigs/> , and CIS Benchmarks™ are available at <https://www.cisecurity.org/cis-benchmarks/> .

An organization's attack surface is broad, and every asset is interconnected. The overall attack surface is composed of every asset's attack surface. To keep this in perspective, every on-premises

device, cloud resource, external service (i.e., software as a service (SaaS), online storage, or software repository), or external network configured to access the organization is part of the attack surface. Attack surface management describes the methods used to *continuously* monitor an environment to identify changes to its attack surface quickly. This type of monitoring seeks to constantly locate shadow-IT and other unknown devices, weak or default passwords, misconfigurations, missing patches, and many other items of concern.

## Managing Attack Surfaces

Managing the attack surface means maintaining awareness of exposed services and ensuring they operate securely per organizational policy. Maintaining awareness necessitates continuous discovery and routine evaluation of configurations to ensure they are secure and working as intended. The most attack-prone area of an organization's infrastructure is the edge, which includes any services exposed to the internet. In 2007, a University of Maryland study identified that internet-connected services experience an attack every 39 seconds, and these numbers are likely worse today ( <https://eng.umd.edu/news/story/study-hackers-attack-every-39-seconds/> ). With these numbers in mind, it is critically important to quantify services exposed to the internet and quickly identify any changes to this footprint.

Two methods to maintain awareness of exposed services include:

| Method            | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Passive discovery | Passive discovery can be a practical approach to managing the attack surface. Passive discovery describes the indirect methods used to identify systems, services, and protocols. Passive discovery, such as network packet capture, can reveal information about network-connected hosts, communications channels, protocols in use, and activity patterns. Passive discovery is beneficial as it leverages careful observation to show characteristics of network-connected software and devices. |
|                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

| Method         | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Edge discovery | Edge discovery seeks to define the "edge" of the network entirely. It is easy to assume that the edge comprises only internet-facing servers. The edge is instead composed of every device with internet connectivity. Assuming attacks will occur from the internet, anything accessible must be considered part of the edge. The US Cybersecurity & Infrastructure Security Agency (CISA) identified that 90% of successful cyberattacks start with a phishing email ( <a href="https://www.cisa.gov/shields-up/">https://www.cisa.gov/shields-up/</a> ). This fact underscores that an organization's edge is much broader than is often assumed. |

## Evaluating the Attack Surface

Sometimes, security controls do not operate as expected; therefore, it is crucial to perform testing to ensure that they are working correctly. Also, security controls are often modified or disabled by support staff while working to resolve trouble tickets. For these reasons, a testing plan must be designed to validate that controls function as intended. For example, validating that firewalls only allow the right traffic to pass, that endpoint protection is operating properly on employee workstations, and that web application firewalls correctly identify and block injection attacks.

Not all control weaknesses or misconfigurations are easy to identify. In the same regard, having confidence that sufficient controls are in place is challenging. Leveraging the analytical skills of an expert practitioner is irreplaceable. Adversary emulation, penetration testing, and bug bounty programs are all designed to assess an organization's security posture as thoroughly as possible. A penetration test involves hiring a trusted offensive security expert to fill the role of an attacker, tasking them to exploit the environment and evaluate the effectiveness of existing protections. The penetration test includes a findings report detailing identified weaknesses and recommended remediations. Another type of penetration test, adversary emulation, seeks to mimic the actions of known threat actor groups. The MITRE ATT&CK® framework typically forms the basis of this type of assessment. After a threat assessment identifies threat actor groups, the ATT&CK framework details their tactics, techniques, and procedures (TTPs). Emulating these TTPs helps assess whether existing protections are sufficient to stop attacks characteristic of the threat actor.

One last assessment method involves offering rewards for responsible disclosure of vulnerabilities. Bug bounties allow organizations to define areas of their environment they would like help protecting. The bug bounty identifies elements of the environment that are in scope for testing and the rewards available for reporting issues. This approach incentivizes offensive security

professionals (ethical hackers) to assess controls continuously and can also help identify unknown and undocumented vulnerabilities. Bugcrowd ( <https://www.bugcrowd.com/> ) and HackerOne ( <https://www.hackerone.com/> ) are popular bug bounty platforms.

## Penetration Testing and Adversary Emulation

Penetration testing and adversary emulation are techniques to assess an organization's attack surface and identify vulnerabilities. Both methods supplement attack surface management and help improve an organization's security posture.

Penetration testing involves simulating an attack on an organization's network to identify vulnerabilities and weaknesses. The goal is to identify the most vulnerable components within an organization's environment and determine how an attacker could exploit them. The penetration test results are then used to prioritize risk mitigation efforts and reduce the attack surface.

Adversary emulation, on the other hand, involves simulating a real-world cyber attack by an actual adversary to assess an organization's defenses. This technique involves a more comprehensive and realistic simulation of a targeted attack. The goal is to identify gaps and weaknesses in an organization's security infrastructure that a known threat actor typically targets. Doing so helps the organization improve its ability to detect and respond to specific attacks associated with the threat actor instead of generalized attacks used in penetration testing.

Organizations can reduce their risk of a successful cyber attack by identifying and mitigating vulnerabilities before attackers exploit them. Attack surface management provides a framework for organizations to assess and manage their attack surface, and penetration testing and adversary emulation are techniques used to evaluate the effectiveness of the organization's security measures.

## Reducing the Attack Surface

Some methods commonly incorporated to reduce the attack surface include the following:

| Method          | Description                                                                                                                                                                                                             |
|-----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Asset inventory | Conducting an inventory of all hardware and software assets and user accounts in the environment. Once identified, the team must determine which assets are essential for business operations and which can be removed. |
|                 |                                                                                                                                                                                                                         |

| Method                          | Description                                                                                                                                                                                                                                                                   |
|---------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Access control                  | Implementing strict access control measures, such as multifactor authentication, can reduce the attack surface significantly. Limiting access to sensitive data and systems reduces the risk of unauthorized access.                                                          |
| Patching and updating           | Regularly patching and updating software and firmware can prevent attackers from exploiting known vulnerabilities. Patching should be performed via automated patch management systems.                                                                                       |
| Network segmentation            | Segmenting a large network into smaller subnets can limit the damage an attacker can cause. By segmenting the network, the breaches and infections can be more effectively contained, thereby reducing the attack surface.                                                    |
| Removing unnecessary components | Removing hardware or software components reduces the attack surface. By removing software, the organization eliminates a pathway that attackers can exploit.                                                                                                                  |
| Employee training               | Employee training can help reduce the attack surface by raising awareness of the potential risks and the importance of security measures. Regular training can help employees recognize and report potential security threats, reducing the likelihood of successful attacks. |

Copyright © CompTIA, Inc. All rights reserved.